

Leitlinie zum Schutz personenbezogener Daten und zur Informationssicherheit

Fassung vom **Datum**
Name, Position

Inhaltsverzeichnis:

1. Präambel
2. Geltungsbereich
3. Grundlagen
4. Ziele
5. Selbstverpflichtung
6. Prinzipien
7. Umsetzung
8. Verpflichtung zur kontinuierlichen Verbesserung
9. Verstöße und Sanktionen
10. Geltungsdauer

1. Präambel

Bei den Dienstleistungen des **Unternehmen „NAME“** ist davon auszugehen, dass personenbezogene Daten (pbD), sowie pbD der besonderen Kategorien (hier Gesundheitsdaten) erhoben und verarbeitet werden müssen, sowie zur Sicherstellung der notwendigen Verfügbarkeit, Vertraulichkeit und Integrität ein angemessenes Informationssicherheitsniveau gewährleistet sein muss.

2. Geltungsbereich

Diese Leitlinie gilt für alle Mitarbeiter und zu erbringenden Leistungen des **Unternehmen „NAME“**. Aufgrund der Unternehmensstruktur und teilweise dezentralen mobilen Arbeitsweise entfällt die Angabe eines räumlichen Geltungsbereichs, dieser erstreckt sich auf alle Standorte sowie mobile Arbeitsorte des Unternehmens. Für das Arbeiten im „Home-Office“ findet diese Leitlinie ebenfalls Geltung, diese Richtlinie wird im Kapitel „Anweisungen für Mitarbeiter“ gesondert geregelt.

3. Grundlagen

Gemäß Artikel 4 Ziffer 1 der EU-Datenschutz-Grundverordnung (EU-DSGVO) sind personenbezogene Daten alle Informationen, die sich auf eine identifizierte

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	1

oder identifizierbare natürliche Person beziehen. Der besondere Schutz personenbezogener Daten ist bereits seit dem Volkszählungsurteil des Bundesverfassungsgerichts vom 15. Dezember 1983 verfassungsrechtlich verankert:

Aus dem allgemeinen Persönlichkeitsrecht ergibt sich ein Recht auf informationelle Selbstbestimmung. Der Datenschutz bezweckt somit den Schutz des Einzelnen vor Beeinträchtigungen in seinem Persönlichkeitsrecht durch den angemessenen Umgang mit seinen personenbezogenen Daten.

Der Umgang mit personenbezogenen Daten in Umsetzung völkerrechtlicher Verpflichtungen ist ab dem 25. Mai 2018 in der EU-DSGVO geregelt, die in den europäischen Staaten und damit auch für den Unternehmen „NAME“ gilt. Damit obliegt es diesem die technischen und organisatorischen Maßnahmen zu treffen die erforderlich sind, um die Ausführung der EU-DSGVO zu gewährleisten.

Der Schutz sensibler betrieblicher Daten, Informationen und Systeme ist ebenfalls eine zwingende Anforderung, obwohl dieser Bereich gesetzlich weniger explizit als der Datenschutz geregelt ist. Diese Anforderung ergibt sich vielfach aus vertraglichen und rechtlichen Verpflichtungen, darüber hinaus aber auch aus Eigeninteresse.

4. Ziele

Mit dieser Leitlinie zum Datenschutz und zur Informationssicherheit gibt sich der Unternehmen „NAME“ den Rahmen für den Umgang mit personenbezogenen Daten und den sicheren Betrieb der informationstechnischen Infrastrukturen, die für die Erfüllung der Organisationsaufgaben benötigt werden.

Die allgemeingültigen Sicherheitsziele sind:

- Vertraulichkeit, Verfügbarkeit, Integrität aller Informationen des Unternehmens zu gewährleisten
- Schutz gegen Angriffe aus dem Internet, die das interne Netzwerk gefährden, zu verhindern
- Geschäftsprozesse und Arbeitsabläufe dokumentieren
- Sichere und vertrauenswürdige Datenverarbeitung
- Erhalt der in die Technik, Arbeitsprozesse und Wissen investierten Werte
- Minimierung der möglichen Ausfallzeit und Schäden durch Systemausfälle
- Etablierung eines starken Bewusstseins für Informationssicherheit innerhalb des Unternehmens

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	2

5. Selbstverpflichtung

Die Geschäftsführung und die Mitarbeiter des **Unternehmen „NAME“** sind sich ihrer Verantwortung bei der Erbringung ihrer Leistungen und im Umgang mit den dafür eingesetzten informationstechnischen Infrastrukturen bewusst. Die Umsetzung von Datenschutz und Informationssicherheit hat einen hohen Stellenwert. Es werden alle notwendigen geeigneten und angemessenen Maßnahmen getroffen, um negative materielle und immaterielle Folgen für Betroffene und den **Unternehmen „NAME“** auszuschließen.

6. Prinzipien

Der Umgang mit personenbezogenen Daten ist in der EU-DSGVO als Verbot mit Erlaubnisvorbehalt geregelt. Damit ist das Verarbeiten von personenbezogenen Daten grundsätzlich verboten. Ausnahmen bestehen nur, wenn ein Gesetz dies erlaubt oder der Betroffene einwilligt. Hieraus leitet der **Unternehmen „NAME“** vier Prinzipien zur Umsetzung des Datenschutzes ab. Diese lauten wie folgt:

1. Das **Unternehmen „NAME“** strebt bei allen seinen Arbeitsvorgängen an, die Verarbeitung von personenbezogenen Daten zu vermeiden (Prinzip der Datenvermeidung).
2. Soweit bei Arbeitsvorgängen die Verarbeitung von personenbezogenen Daten nicht vermieden werden kann, wählt das **Unternehmen „NAME“** im Rahmen des technisch und organisatorisch Vertretbaren jeweils den Arbeitsvorgang, bei dem so wenig personenbezogene Daten wie möglich verarbeitet werden müssen (Prinzip der Erforderlichkeit).
3. Eine Verwendung von personenbezogenen Daten für einen anderen, als den vorab festgelegten oder einem diesem besonders nahen Zweck ist ausgeschlossen. Ausnahmen ergeben sich nur, wenn ein Gesetz dies erlaubt oder der Betroffene einwilligt (Prinzip der Zweckbindung).
4. Bei allen Arbeitsvorgängen werden die gesetzlichen Löschfristen beachtet.

Eine wirksame Umsetzung des Datenschutzes ist nur mit einer wirkungsvollen Informationssicherheit zu erreichen. Zudem folgen für den Pflegedienst PflegeEngel Zeitkreis auch aus grundsätzlichen Erwägungen Anforderungen an die Informationssicherheit. Darum formuliert das **Unternehmen „NAME“** neben den vier Prinzipien zur Umsetzung des Datenschutzes auch drei Prinzipien zur

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	3

Umsetzung der Informationssicherheit. Diese sind:

1. Die Vermeidung von Unterbrechungen und Inkonsistenzen der für den Pflegedienst PflegeEngel Zeitkreis eingesetzten informationstechnischen Infrastrukturen spielt eine maßgebliche Rolle bei der Durchführung der Arbeitsvorgänge und Erbringung der o.a. vier Prinzipien gegenüber den Kunden. Deswegen werden die von der des Unternehmen „NAME“ genutzten informationstechnischen Infrastrukturen so betrieben, dass Ausfälle einzelner Komponenten toleriert werden können (Prinzip der Verfügbarkeit und Fehlerfreiheit).
2. Technische und organisatorische Maßnahmen stellen sicher, dass die Auswirkungen von Unregelmäßigkeiten in Daten oder Fehlfunktionen in informationstechnischen Infrastrukturen vermieden werden, nicht unbemerkt bleiben und zeitlich begrenzt werden (Prinzip der Integrität).
3. Der Schutz sensibler Daten und informationstechnischer Infrastrukturen wird dadurch gewährleistet, dass diese ausschließlich Berechtigten zugänglich gemacht werden (Prinzip der Vertraulichkeit).

Das Unternehmen „NAME“ erbringt ausschließlich Dienste, deren Informationssicherheits- und Datenschutzniveau entsprechend dieser sieben Prinzipien umgesetzt werden kann. Bei der Umsetzung der Prinzipien berücksichtigt dieser ein wirtschaftlich vertretbares Verhältnis im Vergleich zum Wert der betreffenden Informationen und IT-Systeme.

7. Umsetzung

Die Umsetzung der Prinzipien zum Datenschutz und zur Informationssicherheit in den Arbeitsabläufen des Unternehmens „NAME“ erfordert technische und organisatorische Maßnahmen. Diese werden in den Richtlinien zum Management der Informationssicherheit und zum Datenschutzmanagement, den dort verankerten Prozessbeschreibungen und anderen Vorgaben geregelt. Durch die Etablierung eines Datenschutzmanagementsystems (DSMS) und eines Informationssicherheitsmanagementsystems (ISMS) werden kontinuierliche Revisionen dieser Regelungen und deren konsequente Einhaltung für das angestrebte Datenschutz- und Informationssicherheitsniveau sichergestellt. Abweichungen werden unmittelbar mit dem Ziel analysiert, den Datenschutz und die Informationssicherheit zu verbessern und auf dem aktuellen Stand der Technik zu halten.

Aufgrund der besonderen Kategorien personenbezogener Daten, die in einem

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	4

Unternehmen wie unserem erhoben werden, ist dieses Unternehmen verpflichtet einen Datenschutzbeauftragten zu bestellen. Unser betrieblicher /externer Datenschutzbeauftragter stellt die erforderlichen Standards zum Thema Datenschutz und Informationssicherheit zusammen mit der Geschäftsführung und dem ISB (Informationssicherheitsbeauftragten) auf, um diese aufrecht zu erhalten und bei Bedarf an neue rechtliche, technische und organisatorische Gegebenheiten anzupassen. Die hierfür erforderlichen technischen, organisatorischen und personellen Voraussetzungen werden von der Geschäftsführung im Rahmen der Verhältnismäßigkeit geschaffen. Diese trägt auch die Gesamtverantwortung für die Themen Datenschutz und Informationssicherheit.

8. Verpflichtung zur kontinuierlichen Verbesserung

Die Sicherheitskonzeption wird von der Geschäftsleitung und dem ISB / DSB jährlich auf Aktualität und Wirksamkeit geprüft und bei Bedarf angepasst.

9. Verstöße und Sanktionen

Alle Mitarbeiter sind gehalten, im Sinne dieser Leitlinie die Themen Datenschutz und Informationssicherheit aktiv zu unterstützen und zu fördern. Fehler sind menschlich und können passieren. Eine Verletzung von Informationssicherheitsrichtlinien oder Dienstanweisungen kann jedoch bei schuldhaftem Verhalten für einen Beschäftigten arbeitsrechtliche Konsequenzen, bis hin zur Kündigung nach sich ziehen. Grob fahrlässige oder vorsätzliche Verstöße können im Falle finanzieller Schäden die Haftung und damit zu Regressforderungen führen. Auch strafrechtliche Konsequenzen sind in einem solchen Fall nicht ausgeschlossen.

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	5

10. Geltungsdauer

Diese Leitlinie tritt mit Unterzeichnung in Kraft. Sie gilt, bis sie außer Kraft gesetzt oder durch eine neuere Fassung ersetzt wird. Sie wird nach Unterzeichnung allen Mitarbeitern zur Kenntnis gebracht.

Ort, Datum

(Geschäftsführung)

Freigabe	Bearbeiter	Datum	Änderungsstand	Seite
GF	ISB / DSB	TT-MM-JJJJ	0	6